# KrustyLoader Investigation - Student Briefing

## 1. Malware Overview

- Family / type: KrustyLoader (dropper)
- Aliases: Not specified in this scenario
- Behaviour class: Rust-based malware linked to Ivanti ConnectSecure compromises
- What it does:
- Exploits zero-day vulnerabilities CVE-2024-21887 and CVE-2023-46805 in Ivanti Connect Secure VPN product, allowing unauthenticated remote code execution
- Downloads and executes a Sliver backdoor
- No lateral movement, exfiltration, or persistence mechanisms observed
- Associated MITRE ATT&CK techniques:
- Exploitation of Public-Facing Application (T1190)
- Command and Control (T1071)
- Associated CVEs: CVE-2024-21887, CVE-2023-46805

## 2. Exercise Objective

- Investigate the compromise of a victim host exhibiting unusual network activity and suspicious file modifications
- Identify the malware and determine the extent of the intrusion
- Difficulty level: Intermediate
- Cybersecurity approach: Defence-oriented
- NICE work role: Incident Response
- Successful trainee: Will have demonstrated the ability to investigate a compromised host, identify suspicious services and files, and determine the extent of the intrusion

## 3. Sandbox Topology & Malware Emulation

- Hosts:
- staging-server: 192.168.120.5
- victim: 192.168.120.10
- c2-server: 192.168.120.20
- router: 192.168.120.1
- Network: dropper-switch (192.168.120.0/24)
- Malware emulation:
- Suspicious service: session-mgr.timer (emulates the malware's persistence mechanism)
- Suspicious file: rat.sh (emulates the malware's remote access functionality)
- C2 communication: Emulated by the session-mgr.timer service connecting to c2-server on port 6060
- Scheduled task: session-mgr.timer (emulates the malware's scheduled execution)

```
dropper-switch (192.168.120.0/24)
|
|-- router (192.168.120.1)
|-- staging-server (192.168.120.5)
|-- victim (192.168.120.10)
|-- c2-server (192.168.120.20)
```

## 4. Student Tasks

- ACCESS step:
- Credentials: Username: cyrano, Password: cyrano
- Passkey: start

- TRAINING_LEVEL 1:
- Task: Investigate the suspicious service running on the compromised host
- TYPE of artifact/flag expected: Service name
- TRAINING_LEVEL 2:
- Task: Determine whether a scheduled task or timer is responsible for automatically executing suspicious activity
- TYPE of artifact/flag expected: Timer name
- TRAINING_LEVEL 3:
- Task: Locate files introduced onto the system by the malicious software
- TYPE of artifact/flag expected: Filename

## 5. Solution Walkthrough & Flags

- TRAINING_LEVEL 1:
- Methodology:
  1. Log in to the victim host using the provided credentials.
  2. List all running services using the command: systemctl list-units --type=service
  3. Identify the suspicious service named "session-mgr.timer".
  4. Inspect the service details using the command: systemctl cat session-mgr.timer
- Flag: session-mgr.timer
- TRAINING_LEVEL 2:
- Methodology:
  1. List all timers using the command: systemctl list-timers
  2. Identify the timer named "session-mgr.timer".
  3. Inspect the timer details using the command: systemctl cat session-mgr.timer
- Flag: session-mgr.timer
- TRAINING_LEVEL 3:
- Methodology:
  1. Navigate to the directory /tmp/.session using the command: cd /tmp/.session
  2. List the files in the directory using the command: ls -la
  3. Identify the suspicious file named "rat.sh".
- Flag: rat.sh

## 6. Knowledge Gained

- Skills:
- Investigating compromised hosts
- Identifying suspicious services and files
- Analyzing scheduled tasks and timers
- Tools:
- systemctl
- ls
- cd
- Concepts:
- Malware persistence mechanisms
- Command and Control (C2) communication
- Incident response procedures
- NICE role: Incident Response
- MITRE techniques: Exploitation of Public-Facing Application (T1190), Command and Control (T1071)